SIMATS ENGINEERING
ASSESSMENT TOOL 2

COURSE NAME: CRYPTOGRAPHY AND NETWORK SECURITY
COURSE CODE: CSA5116

COURSE OUTCOME COVERED

CO2: Analyze Public Key crypto system strategies using RSA and key Exchange for Encryption algorithm to strengthen information security. (BL4,BL5)

Assessment Tool Weightage : 20%

QUESTIONS: **Total Marks: 50**

Annexure A

Scenario-Based

Code of Conduct:

I V. Sandeep Reddy(192325096)(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:
V. Sandeep Reddy

Annexure A
Scenario-based

1. Secure Data Transmission using Block Cipher
A company is transmitting repeated financial data blocks over a network. Initially, they used ECB mode and noticed patterns in ciphertext.

A. Explain why this issue occurs.
B. Suggest a more secure block cipher mode and justify your choice based on the scenario.

2. Choosing an Encryption Algorithm for Banking System
A banking application needs high security and moderate performance for encrypting customer transactions. The available options are DES, 3-DES, and Blowfish.

A. Identify the most suitable algorithm for this scenario.
B. Justify your choice based on security strength and efficiency.

3. Key Exchange in an Unsecured Network
Two users want to establish a secure communication channel over a public network using Diffie-Hellman key exchange. However, the network is vulnerable to attacks.

A. Explain how the key exchange works in this scenario.
B. Identify a possible security threat and suggest a solution to mitigate it.

4. Public Key Cryptography for Email Security
An organization plans to implement RSA for secure email communication.

A. Describe how RSA can be used for encryption and decryption in this scenario.
B. Explain how key distribution and management play a role in maintaining security.

5. Cryptography for IoT Devices
A smart home system uses low-power IoT devices that need secure communication. The designer must choose between RSA and Elliptic Curve Cryptography (ECC).

A. Analyze the constraints of IoT devices.
B. Recommend a suitable cryptographic approach and justify your answer.

RUBRICS FOR CALCULATION:

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Scenario	20%	Demonstrates clear and complete understanding of the scenario and context	Shows good understanding with minor gaps	Partial understanding; misses key aspects	Misinterprets or fails to understand the scenario
Identification of Key Issues	20%	Accurately identifies all relevant issues and factors involved	Identifies most key issues with minor omissions	Identifies limited issues; some irrelevant points	Unable to identify key issues
Application of Concepts	25%	Applies appropriate concepts effectively to address the scenario	Applies concepts with minor errors	Limited or partially correct application	Unable to apply relevant concepts
Decision Making	20%	Makes well-reasoned, logical decisions with strong rationale	Makes reasonable decisions with some justification	Makes weak decisions with limited justification	No clear decisions made or rationale provided
Clarity of Response	15%	Response is clear, structured, and logically presented	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganized and difficult to understand

3. Key Exchange in an Unsecured Network

A. Comprehensive Mechanism of Diffie-Hellman Key Exchange

The Diffie-Hellman key exchange protocol allows two parties to establish a shared secret over an insecure communications channel without transmitting the secret itself. The detailed step-by-step process is as follows:

- **Public Parameter Agreement:** Alice and Bob publicly agree on two large positive integers: a large prime number p and a primitive root modulo p, denoted as g. These parameters can be known to any eavesdropper.
- **Private Key Generation:**
  - Alice selects a random, secret integer a (her private key), which she keeps strictly confidential.
  - Bob selects a random, secret integer b (his private key), which he also keeps strictly confidential.
- **Public Value Computation & Exchange:**
  - Alice computes her public value using the modular exponentiation formula:

$$A = g^a \pmod{p}$$

She then transmits A to Bob over the public network.

  - Bob computes his public value using the formula:

$$B = g^b \pmod{p}$$

He then transmits B to Alice over the public network.

- **Shared Secret Derivation:**
  - Upon receiving B from Bob, Alice computes the shared secret S by raising Bob's public value to the power of her private key modulo p:

$$S = B^a \pmod{p} = \left(g^b\right)^a \pmod{p} = g^{ab} \pmod{p}$$

  - Upon receiving A from Alice, Bob computes the shared secret S by raising Alice's public value to the power of his private key modulo p:

$$S = A^b \pmod{p} = (g^a)^b \pmod{p} = g^{ab} \pmod{p}$$

  - Both parties now share the identical secret key $S = g^{ab} \pmod{p}$, which can be used as a symmetric encryption key for subsequent communication sessions.

B. Security Threat and Mitigation Strategy

- **Security Threat (Man-in-the-Middle / MitM Attack):**
  - The standard Diffie-Hellman algorithm does not authenticate the communicating parties. Because of this architectural limitation, it is highly vulnerable to a **Man-in-the-Middle attack** (often orchestrated by an attacker named Mallory).
  - Mallory can intercept Alice's public value A and send her own public value M_1 to Bob. Simultaneously, she intercepts Bob's public value B and sends her own public value M_2 to Alice.

- Consequently, Alice shares a secret key with Mallory, and Bob shares a separate secret key with Mallory. Mallory can then seamlessly decrypt, read, modify, and re-encrypt all traffic passing between Alice and Bob without either party realizing their channel has been compromised.

- **Mitigation Strategy:**
  - To prevent MitM attacks, the key exchange must be integrated with an authentication mechanism. This is typically achieved using **Digital Signatures** (such as RSA or ECDSA signatures) where each user signs their public value using their long-term private key.
  - Alternatively, organizations deploy a **Public Key Infrastructure (PKI)** utilizing trusted **X.509 digital certificates** issued by a Certificate Authority (CA) to cryptographically verify the real identities of Alice and Bob prior to or during the key exchange phase.

4. Public Key Cryptography for Email Security

A. RSA Implementation for Email Encryption and Decryption

RSA is an asymmetric cryptographic algorithm that utilizes a mathematically linked public-private key pair to ensure the confidentiality and integrity of email communications.

- **Key Generation Phase:**
  - An organization member selects two distinct, large prime numbers, p and q, and computes their product $n = p \times q$, which serves as the **modulus** for both keys.
  - The Euler's totient is calculated as $\phi(n) = (p-1)(q-1)$.
  - An integer e (the **public exponent**) is chosen such that it is coprime to $\phi(n)$.
  - The **private exponent** d is computed as the modular multiplicative inverse of e modulo $\phi(n)$, satisfying $d \cdot e \equiv 1 \pmod{\phi(n)}$.
  - The public key is published as (e, n), while the private key is kept secret as (d, n).
- **Encryption Phase (Sending a Secure Email):**
  - When a sender wishes to transmit a confidential email message M to a recipient, the sender looks up the recipient's public key (e, n).
  - The message is converted into integer blocks and encrypted using the recipient's public key formula:
    $$C = M^e \pmod{n}$$
  - The ciphertext C is then transmitted over the network. Even if intercepted, the message cannot be read without the private key.
- **Decryption Phase (Reading the Secure Email):**
  - Upon receiving the ciphertext C, the legitimate recipient applies their confidential private key (d, n) using the decryption formula:
    $$M = C^d \pmod{n} = (M^e)^d \pmod{n} = M^{ed} \pmod{n} = M$$

- The original plaintext message M is recovered successfully.

B. The Role of Key Distribution and Management in Email Security

- **Critical Importance of Key Distribution:**
  - Public-key cryptography relies heavily on the premise that public keys are accessible and authentic. If an attacker can tamper with or spoof the distribution channels, they could publish a fake public key under a legitimate user's name. Senders would then inadvertently encrypt sensitive emails using the attacker's key, enabling the attacker to intercept and decrypt all incoming messages.
- **Role of Key Management Infrastructure:**
  - To mitigate distribution risks, organizations implement comprehensive **Key Management Systems (KMS)** and **Public Key Infrastructures (PKI)**.
  - **Certificate Authorities (CAs):** Trusted third-party entities that bind public keys to verified organizational identities via digital certificates (such as X.509 standards).
  - **Directory Services:** Secure repositories (like LDAP servers) where users can reliably query and retrieve authentic public keys.
  - **Lifecycle Management:** Policies governing secure key generation, hardware security module (HSM) storage, automated key rotation, and immediate certificate revocation (via Certificate Revocation Lists [CRLs] or Online Certificate Status Protocol [OCSP]) to handle compromised or expired keys safely.